

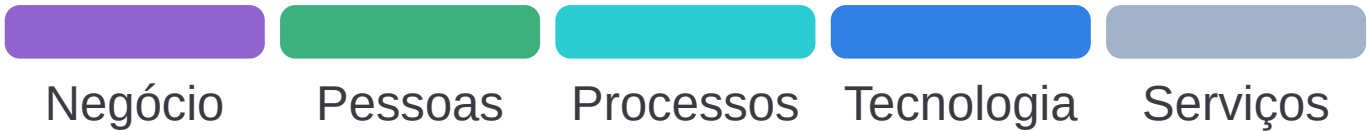
FORTINET Quickscan SecOps · SOC-CMM

Relatório indicativo de maturidade de operações de segurança

Screening indicativo de alto nível. Não substitui um assessment formal.

SESSÃO Sem rótulo DATA DA SESSÃO 24/08/2026 02:42:31
RELATÓRIO GERADO EM 24/08/2026 02:42:32 VERSÃO DA FERRAMENTA 3.4.0-dev.4.8.0.7
COBERTURA DA EVIDÊNCIA 15 de 15 respostas confirmadas

1. Negócio 2. Pessoas 3. Processos 4. Tecnologia 5. Serviços



Screening indicativo de alto nível. Não substitui um assessment formal.

COMO INTERPRETAR ESTE RELATÓRIO

- O **score** e o **estágio** vêm exclusivamente das **respostas confirmadas** do assessment.
- O **contexto tecnológico não altera a nota**: ter a ferramenta não eleva a maturidade.
- O contexto **refina a classificação do gap e as recomendações** — é o que torna a leitura acionável.
- n/d** significa **não avaliado**, nunca zero; zero confirmado é um resultado medido.
- O **cenário-alvo** é um estado desejado e declarado, não previsão nem compromisso.
- As **recomendações são possibilidades** condicionadas ao contexto informado, sujeitas a validação.

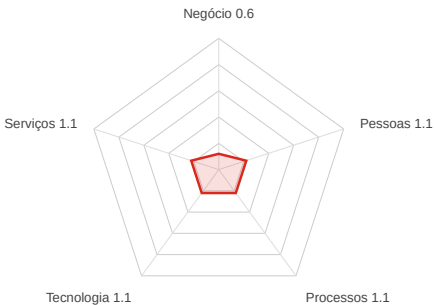
Resumo de maturidade



Você está aqui

1.0 / 5 · Inicial

Negócio	Pessoas	Processos	Tecnologia	Serviços
0.6	1.1	1.1	1.1	1.1



Prioridades declaradas pelo negócio

1. A operação de segurança tem objetivos e direcionamento claros, conectados...

2. A equipe de segurança tem capacidade e redundância compatíveis com a...

3. Como os eventos e logs de segurança são centralizados e analisados hoje?

Gaps de maturidade observados

Gap alto de maturidade **Direcionamento e objetivos** · domínio Negócio

EVIDÊNCIA DECLARADA: Não há direcionamento formal — Segurança atua principalmente por demanda.

CAPABILITY A DESENVOLVER: Direcionamento e responsabilidades de segurança

Gap alto de maturidade **Governança** · domínio Negócio

EVIDÊNCIA DECLARADA: Responsabilidade indefinida — Ninguém possui claramente a accountability.

CAPABILITY A DESENVOLVER: Governança e reporte de risco

Gap alto de maturidade **Capacidade do time** · domínio Pessoas

EVIDÊNCIA DECLARADA: Capacidade insuficiente — A demanda excede a equipe; atividades relevantes ficam sem dono.

CAPABILITY A DESENVOLVER: Capacidade e resiliência do time

Gap alto de maturidade **Resposta a incidentes** · domínio Processos

EVIDÊNCIA DECLARADA: Sem processo definido — A resposta depende da situação e de quem está disponível.

CAPABILITY A DESENVOLVER: Gestão e execução de resposta a incidentes

Gap alto de maturidade **Centralização de logs** · domínio Tecnologia

EVIDÊNCIA DECLARADA: Sem centralização — Cada ferramenta mantém seus logs; a investigação depende de consultas isoladas.

CAPABILITY A DESENVOLVER: Análise centralizada, correlação e retenção de eventos

POSSÍVEIS CAMINHOS DE APOIO

Para a capability **Análise centralizada, correlação e retenção de eventos**:

Contexto tecnológico não declarado para esta capability: as opções abaixo exigem **validar aderência** antes de qualquer recomendação.

- **FortiAnalyzer** — logging e analytics no ecossistema Fortinet declarado; validar aderência ao contexto do cliente.
- **FortiSIEM** — necessidade SIEM ampla de TI/OT, com múltiplas fontes e correlação em escala; validar aderência ao contexto do cliente.
- **FortiSOC** — abordagem integrada, condicionada à arquitetura declarada; validar aderência ao contexto do cliente.

Gap alto de maturidade **Cobertura de monitoramento** · domínio Serviços

EVIDÊNCIA DECLARADA: Cobertura insuficiente para a necessidade — Eventos críticos podem permanecer sem triagem durante períodos em que o negócio exige resposta.

CAPABILITY A DESENVOLVER: Cobertura de monitoramento alinhada ao risco

Gap moderado de maturidade **Políticas e privacidade** · domínio Negócio

EVIDÊNCIA DECLARADA: Existem parcialmente — Documentos dispersos ou pouco comunicados.

CAPABILITY A DESENVOLVER: Políticas de segurança e privacidade (LGPD)

Gap moderado de maturidade **Capacitação** · domínio Pessoas

EVIDÊNCIA DECLARADA: Treinamento eventual — Depende de iniciativa individual ou necessidade pontual.

CAPABILITY A DESENVOLVER: Desenvolvimento de competências do time

Gap moderado de maturidade **Conhecimento operacional** · domínio Pessoas

EVIDÊNCIA DECLARADA: Documentação parcial — Existe, mas desatualizada ou incompleta.

CAPABILITY A DESENVOLVER: Gestão de conhecimento operacional

Gap moderado de maturidade **Casos de uso de detecção** · domínio Processos

EVIDÊNCIA DECLARADA: **Gestão reativa** — Regras ajustadas após falsos positivos, incidentes ou problemas.

CAPABILITY A DESENVOLVER: **Ciclo de vida de detecção (detection engineering)**

POSSÍVEIS CAMINHOS DE APOIO

Para a capability **Ciclo de vida de detecção (detection engineering)**:

Contexto tecnológico não declarado para esta capability: as opções abaixo exigem **validar aderência** antes de qualquer recomendação.

- **FortiSIEM** — coleta, correlação e analytics quando a detecção precisa cobrir fontes heterogêneas; validar aderência ao contexto do cliente.
- **FortiAnalyzer** — logging e analytics quando a operação já é majoritariamente Fortinet; validar aderência ao contexto do cliente.
- **FortiSOAR** — orquestração do ciclo de investigação e resposta dos casos de uso; validar aderência ao contexto do cliente.
- **FortiSOC** — abordagem integrada de SOC, como opção de plataforma — nunca como produto obrigatório; validar aderência ao contexto do cliente.

Gap moderado de maturidade **Automação** · domínio Processos

EVIDÊNCIA DECLARADA: **Automações pontuais** — Scripts ou integrações isoladas.

CAPABILITY A DESENVOLVER: **Orquestração e automação de resposta**

POSSÍVEIS CAMINHOS DE APOIO

Para a capability **Orquestração e automação de resposta**:

Contexto tecnológico não declarado para esta capability: as opções abaixo exigem **validar aderência** antes de qualquer recomendação.

- **FortiSOAR** — playbooks, integrações e padronização do tratamento; validar aderência ao contexto do cliente.
- **Automação nativa de FortiAnalyzer/FortiSIEM** — somente quando a necessidade e a arquitetura declaradas forem compatíveis; validar aderência ao contexto do cliente.

Gap moderado de maturidade **Proteção de endpoint** · domínio Tecnologia

EVIDÊNCIA DECLARADA: **EDR parcial** — Somente parte do parque, ou com funções limitadas.

CAPABILITY A DESENVOLVER: **Detecção e resposta em endpoint (EDR)**

Gap moderado de maturidade **Visibilidade de rede** · domínio Tecnologia

EVIDÊNCIA DECLARADA: **Visibilidade parcial** — Alguns segmentos ou ferramentas fornecem visibilidade, mas existem lacunas relevantes de cobertura ou análise.

CAPABILITY A DESENVOLVER: **Network Detection & Response**

Gap moderado de maturidade **Superfície externa** · domínio Serviços

EVIDÊNCIA DECLARADA: **Consultas pontuais** — Após incidentes ou por demanda.

CAPABILITY A DESENVOLVER: **Gestão de exposição externa (EASM/DRPS)**

Gap moderado de maturidade **Gestão de vulnerabilidades** · domínio Serviços

EVIDÊNCIA DECLARADA: **Scans recorrentes sem ciclo** — A descoberta acontece; a correção não segue processo consistente.

CAPABILITY A DESENVOLVER: **Gestão contínua de vulnerabilidades**

POSSÍVEIS CAMINHOS DE APOIO

Para a capability **Gestão contínua de vulnerabilidades**:

Contexto tecnológico não declarado para esta capability: as opções abaixo exigem **validar aderência** antes de qualquer recomendação.

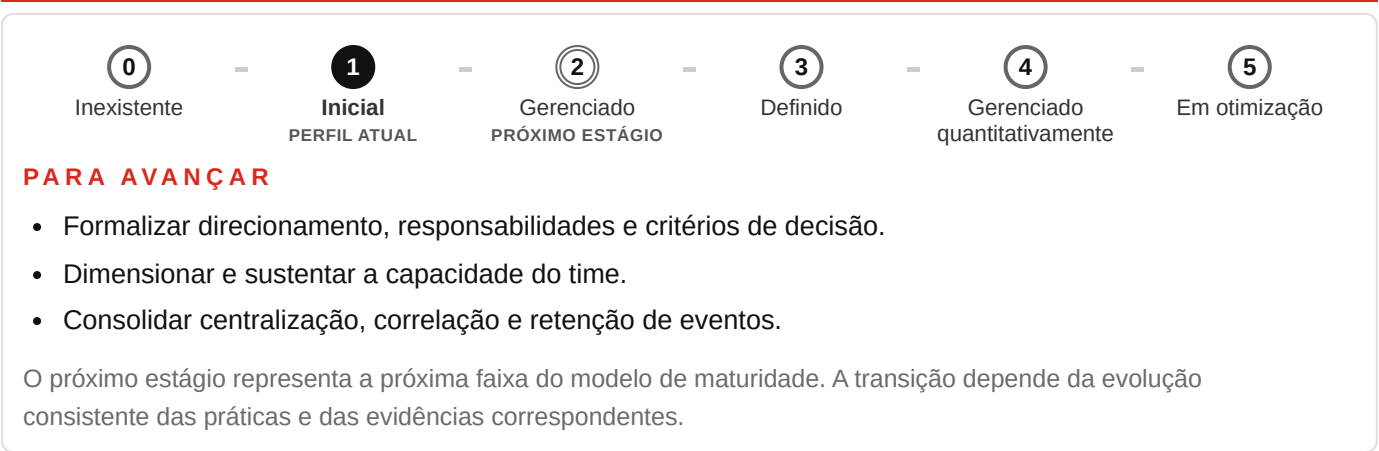
- **FortiClient administrado por EMS** — descoberta, inventário, varredura e patching no escopo de endpoint; não substitui uma plataforma completa de gestão de vulnerabilidades; validar aderência ao contexto do cliente.
- **FortiRecon** — exposição externa (EASM/DRPS) — pertinente à superfície externa, não à gestão interna; validar aderência ao contexto do cliente.

Contexto tecnológico

Não informado nesta sessão **não informado**

Nenhuma capability, contexto de arquitetura, plataforma, licenciamento ou requisito específico foi declarado nesta sessão. A ausência de contexto é um estado legítimo e completo do assessment: ela não altera score, estágio, suficiência nem gaps — apenas mantém a leitura de apoio em base geral, sem afirmar aderência a produto algum.

Jornada de maturidade



Leitura executiva

O Quickscan posiciona a operação em Inicial (1.0/5), com maior consistência relativa em Pessoas, Processos, Tecnologia e Serviços e oportunidades mais relevantes de evolução em Negócio. A distribuição mostra que a evolução não é uniforme entre os domínios avaliados.

Considerando as prioridades declaradas pelo negócio — Direcionamento e objetivos, Capacidade do time e Centralização de logs —, foram observados 6 gaps altos e 9 moderados, que concentram os principais pontos de evolução identificados nesta sessão.

Os próximos passos mais consistentes envolvem: formalizar direcionamento, responsabilidades e critérios de decisão; dimensionar e sustentar a capacidade do time; consolidar centralização, correlação e retenção de eventos. O contexto tecnológico não foi informado nesta sessão; por isso, a leitura evita inferir presença ou ausência de ferramentas.

Anexo — respostas da sessão

1. A operação de segurança tem direcionamento, responsabilidades e objetivos claros, conectados ao negócio?

Não há direcionamento formal

Segurança atua principalmente por demanda.

2. Há governança de segurança estabelecida — papéis, responsabilidades e reporte à liderança?

Responsabilidade indefinida

Ninguém possui claramente a accountability.

3. Políticas de segurança e privacidade (incluindo LGPD) estão definidas e vigentes?

Existem parcialmente

Documentos dispersos ou pouco comunicados.

4. A equipe de segurança tem capacidade e redundância compatíveis com a demanda — sem depender de poucas pessoas?

Capacidade insuficiente

A demanda excede a equipe; atividades relevantes ficam sem dono.

5. Quem opera segurança recebe treinamento e desenvolvimento contínuos?

Treinamento eventual

Depende de iniciativa individual ou necessidade pontual.

6. O conhecimento da operação está documentado — ou concentrado em poucas cabeças?

Documentação parcial

Existe, mas desatualizada ou incompleta.

7. Como a resposta a incidentes acontece hoje?

Sem processo definido

A resposta depende da situação e de quem está disponível.

8. As detecções são gerenciadas como casos de uso — criadas, validadas e revisadas?

Gestão reativa

Regras ajustadas após falsos positivos, incidentes ou problemas.

9. Ações de triagem e resposta são automatizadas — ou 100% manuais?

Automações pontuais

Scripts ou integrações isoladas.

10. Como os eventos e logs de segurança são centralizados e analisados hoje?

Sem centralização

Cada ferramenta mantém seus logs; a investigação depende de consultas isoladas.

11. Qual a capacidade de detecção e resposta nos endpoints hoje?

EDR parcial

Somente parte do parque, ou com funções limitadas.

12. A operação possui visibilidade e capacidade de detectar comportamento suspeito no tráfego de rede, inclusive tráfego leste-oeste e ativos onde agentes não chegam?

Visibilidade parcial

Alguns segmentos ou ferramentas fornecem visibilidade, mas existem lacunas relevantes de cobertura ou análise.

13. A operação possui cobertura de monitoramento compatível com a criticidade, os SLAs e o risco do negócio — inclusive fora do horário comercial quando necessário?

Cobertura insuficiente para a necessidade

Eventos críticos podem permanecer sem triagem durante períodos em que o negócio exige resposta.

14. A superfície externa é monitorada — credenciais vazadas, marca, exposição na internet?

Consultas pontuais

Após incidentes ou por demanda.

15. A gestão de vulnerabilidades é contínua e priorizada — não apenas um scan eventual?

Scans recorrentes sem ciclo

A descoberta acontece; a correção não segue processo consistente.